

DIAGNÓSTICO DE SEGURIDAD · 24 DE JUNIO DE 2026

Diagnóstico de Impacto en el Negocio

Estudio Jurídico Ejemplo SpA

estudioejemplo.cl

40

PUNTAJE DE RIESGO / 100

Medio

01 · RESUMEN EJECUTIVO

Resumen Ejecutivo

Diagnóstico de seguridad del dominio **estudioejemplo.cl** realizado mediante reconocimiento pasivo e inspección de los servicios expuestos públicamente en internet. No se realizaron pruebas de intrusión activa.

0

CRÍTICOS

1

ALTOS

2

MEDIOS

2

BAJOS

Se identificaron vulnerabilidades en la configuración de correo electrónico que permiten la suplantación del dominio (@estudioejemplo.cl). Un atacante puede enviar correos haciéndose pasar por Estudio Jurídico Ejemplo SpA, comprometiendo datos personales de clientes y vulnerando el deber de seguridad bajo la Ley 21.719. Se recomienda implementar DMARC con p=reject como prioridad inmediata.

SEGURIDAD DE CORREO ELECTRÓNICO

SPF

SPF con mecanismo permisivo (~all)

⚠ **Medio** — spoofing parcial posible desde IPs no listadas

```
v=spf1 include:_spf.google.com ~all
```

DMARC

DMARC presente pero con p=none (sin efecto real)

⚠ **Alto** — correos fraudulentos no son rechazados automáticamente

```
v=DMARC1; p=none; rua=mailto:rua@dmARC.example.com
```

ENTREGABILIDAD DE CORREO

Sus correos pueden rebotar o llegar a spam

⚠ **Crítico** — correos propios rebotando o en spam

MTA-STS

MTA-STS no configurado — TLS no forzado en correos entrantes

⚠ **Medio** — sin garantía de cifrado en tránsito

⚠ **Sus correos pueden rebotar o llegar a spam.** Sin registros SPF y DMARC correctamente configurados, los servidores de destino tienen razones técnicas válidas para rechazar o filtrar correos enviados desde @estudioejemplo.cl. Esto afecta tanto los correos hacia clientes como las respuestas que usted espera recibir. Además, cualquier persona puede enviar correos haciéndose pasar por su organización sin que los destinatarios puedan distinguirlos de los legítimos.

Este informe fue generado mediante reconocimiento pasivo e inspección de servicios expuestos públicamente. No se realizaron pruebas de explotación activa ni acceso no autorizado a sistemas. Los hallazgos representan riesgos potenciales identificados desde internet, sin autenticación.

Análisis de Impacto en el Negocio

Basado en los hallazgos técnicos identificados, los siguientes escenarios representan los riesgos de negocio concretos para **Estudio Jurídico Ejemplo SpA** en caso de no remediar las vulnerabilidades.

Fraude BEC — Suplantación de Identidad por Correo

ALTO

El dominio @estudioejemplo.cl tiene DMARC activo pero con política p=none, que solo monitorea sin bloquear. Cualquier atacante puede enviar correos suplantando @estudioejemplo.cl a clientes, proveedores o autoridades sin restricción técnica. En un estudio jurídico esto permite emitir instrucciones falsas de pago, modificar plazos procesales o suplantar comunicaciones con tribunales.

Email spoofing → instrucción falsa → transferencia o acción fraudulenta

IMPACTO FINANCIERO

Fraude promedio BEC en Latinoamérica: USD 62.000 por incidente (FBI IC3 2023). Para PYMES chilenas: pérdidas estimadas entre UF 500-5.000 por evento. Bajo la Ley 21.719, un incidente que exponga datos personales puede derivar en multas de hasta 10.000 UTM (~CLP 740 millones).

IMPACTO REPUTACIONAL

Los clientes de Estudio Jurídico Ejemplo SpA pueden recibir correos fraudulentos que parecen legítimos. La obligación de notificar a la APDP y a los afectados dentro de 72 horas agrava el impacto reputacional y puede derivar en demandas de responsabilidad civil.

Para estudios jurídicos, clínicas y oficinas contables, la suplantación de correo permite acceder a datos personales sensibles (información médica, judicial, financiera). La Ley 21.719 exige consentimiento explícito para datos sensibles — un compromiso de correo destruye esa cadena de consentimiento.

Spoofing Parcial — Correos desde Servidores No Autorizados

MEDIO

El SPF de estudioejemplo.cl usa ~all (softfail): servidores no autorizados pueden enviar correos que algunos sistemas antispam aceptan. Un atacante puede usar infraestructura de terceros para distribuir phishing en nombre de Estudio Jurídico Ejemplo SpA.

SPF ~all bypass → phishing dirigido → robo de credenciales o fraude

IMPACTO FINANCIERO

Campañas dirigidas a clientes pueden resultar en demandas por daños. Corrección de ~all a -all: costo técnico mínimo, impacto preventivo alto.

IMPACTO REPUTACIONAL

Los correos phishing pueden circular durante días antes de ser detectados. Cada cliente afectado representa un riesgo legal para la organización.

Phishing dirigido a clientes constituye uso no autorizado de la identidad del responsable del tratamiento. Las víctimas pueden ejercer derechos ARCO (acceso, rectificación, cancelación, oposición) y exigir explicaciones bajo Art. 5° de la Ley 21.719.

OBLIGACIONES BAJO LA LEY 21.719 DE PROTECCIÓN DE DATOS PERSONALES

LEY 21.719 Art. 14 ter — Medidas de seguridad

Las organizaciones que tratan datos personales deben implementar medidas técnicas y organizativas apropiadas al riesgo del tratamiento. La configuración de correo electrónico (DMARC/SPF/TLS) es un control técnico básico exigible, especialmente al manejar datos sensibles como información médica, jurídica o financiera.

⚠ **Consecuencia: Infracción grave: hasta 10.000 UTM (~CLP 740 millones). Para PYMES durante el primer año de vigencia (diciembre 2026 - diciembre 2027), la sanción es amonestación pública en el Registro Nacional de Sanciones y Cumplimiento. Después de ese período, las multas aplican plenamente.**

LEY 21.719 Art. 14 quinquies — Notificación de brechas

Obligación de notificar a la Agencia de Protección de Datos Personales (APDP) y a los titulares afectados dentro de 72 horas ante una brecha de seguridad que represente riesgo para los derechos de las personas. La notificación debe incluir naturaleza de la brecha, datos afectados y medidas adoptadas.

⚠ **Consecuencia: Omitir o demorar la notificación califica como infracción gravísima: hasta 20.000 UTM (~CLP 1.480 millones) o 4% de los ingresos anuales en caso de reincidencia. Las sanciones se publican en el Registro Nacional de Sanciones por 5 años.**

LEY 21.719 Art. 14 bis — Registro de actividades de tratamiento

Mantener un registro actualizado de las actividades de tratamiento de datos personales. La APDP fiscaliza evidencia operativa. Las

Plan de Remediación con Costos Detallados

ACCIÓN TÉCNICA	COSTO UF
Endurecer DMARC de p=none a p=reject	UF 1.0
Cambiar SPF de ~all a -all	UF 0.5
Total inversión en remediación	UF 1.5

INVERSIÓN EN REMEDIACIÓN

UF 1.5

Una sola vez, costo técnico documentado

vs

EXPOSICIÓN ANTE UN INCIDENTE

UF 500-5000

+ multa hasta 20000 UTM (~CLP 1.480 millones)

04 · HALLAZGOS

Tabla de Hallazgos

ID	SEVERIDAD	HALLAZGO	CATEGORÍA	CVSS	RIESGO DE CONTINUIDAD
VULN-002	ALTA	DMARC configurado con p=none (sin enforcement) estudioejemplo.cl	Seguridad de correo electrónico	7.0–8.9	BAJO
VULN-001	MEDIA	SPF configurado con softfail (~all) estudioejemplo.cl	Seguridad de correo electrónico	4.0–6.9	BAJO
VULN-004	MEDIA	Cabeceras de seguridad HTTP ausentes https://estudioejemplo.cl	Cabeceras HTTP de seguridad (A05:2021)	4.0–6.9	BAJO
VULN-003	BAJA	MTA-STX no configurado estudioejemplo.cl	Seguridad de correo electrónico	0.1–3.9	MEDIO
VULN-005	BAJA	Versión TLS obsoleta habilitada https://estudioejemplo.cl	Configuración TLS/SSL (A02:2021)	0.1–3.9	MEDIO
GRP-006	INFORMATIVA	CMS WordPress (1 hallazgos) https://estudioejemplo.cl	CMS WordPress	0.0	BAJO

Detalle de Hallazgos

VULN-002DMARC configurado con p=none (sin enforcement)		ALTA
HOST AFECTADO estudioejemplo.cl CVSS 7.0-8.9	CATEGORÍA Seguridad de correo electrónico	
¿QUÉ SIGNIFICA ESTE HALLAZGO? El dominio tiene DMARC pero con política p=none, que solo monitorea sin rechazar correos fraudulentos. Cualquier servidor puede suplantar @estudioejemplo.cl y los destinatarios recibirán el correo normalmente. Registro actual: v=DMARC1; p=none; rua=mailto:rua@dmARC.example.com		
RECOMENDACIÓN Escalar la política DMARC progresivamente: 1) p=quarantine para mover sospechosos a spam, 2) p=reject para bloquear definitivamente. Agregar rua=mailto:dmARC@estudioejemplo.cl para recibir reportes.		
REFERENCIAS https://dmARC.org/overview/ https://dmARCguide.globalcyberalliance.org/		

VULN-001SPF configurado con softfail (~all)		MEDIA
HOST AFECTADO estudioejemplo.cl CVSS 4.0-6.9	CATEGORÍA Seguridad de correo electrónico	
¿QUÉ SIGNIFICA ESTE HALLAZGO? El registro SPF usa ~all (softfail) en lugar de -all (hardfail). Esto permite que servidores no autorizados envíen correos que pueden pasar filtros antispam. Registro actual: v=spf1 include:_spf.google.com ~all		
RECOMENDACIÓN Cambiar el mecanismo final de ~all a -all una vez verificadas todas las fuentes legítimas de envío del dominio.		
REFERENCIAS https://www.rfc-editor.org/rfc/rfc7208		

VULN-004Cabeceras de seguridad HTTP ausentes		MEDIA
HOST AFECTADO https://estudioejemplo.cl CVSS 4.0-6.9	CATEGORÍA Cabeceras HTTP de seguridad (A05:2021)	
¿QUÉ SIGNIFICA ESTE HALLAZGO? Sin descripción disponible.		
RECOMENDACIÓN Implementar: Content-Security-Policy, X-Frame-Options, Strict-Transport-Security.		

Marco Legal Aplicable

Ley 21.719 — Protección de Datos Personales

Los hallazgos de este informe se relacionan directamente con la Ley 21.719 de Protección de Datos Personales, que entra en plena vigencia el 1 de diciembre de 2026. La ley aplica a toda organización que trate datos personales en Chile, sin importar su tamaño. La Agencia de Protección de Datos Personales (APDP) fiscaliza evidencia técnica operativa, no solo políticas: medidas de seguridad documentadas, registro de tratamientos y notificación oportuna de brechas. Para PYMEs, el primer año (diciembre 2026 - diciembre 2027) las sanciones se limitan a amonestaciones públicas inscritas en el Registro Nacional de Sanciones y Cumplimiento por 5 años.

OWASP TOP 10 (2021)

Estándar internacional para vulnerabilidades en aplicaciones web. Todos los hallazgos están clasificados según esta metodología, reconocida por organismos reguladores y auditores a nivel global.

owasp.org/www-project-top-ten/

MARCO DE CIBERSEGURIDAD NIST

Marco metodológico internacional aplicable como referencia técnica para demostrar el deber de seguridad ante la APDP (Art. 14 ter, Ley 21.719). Las cinco funciones son: Identificar · Proteger · Detectar · Responder · Recuperar.

nist.gov/cyberframework

⚠ AMONESTACIÓN PÚBLICA — REGISTRO NACIONAL DE SANCIONES Y CUMPLIMIENTO

Aunque las PYMEs durante el primer año de vigencia (diciembre 2026 - diciembre 2027) no enfrentan multas económicas, las amonestaciones se publican obligatoriamente en el **Registro Nacional de Sanciones y Cumplimiento** por un período de 5 años. Este registro es público y consultable.

Para su empresa, aparecer en este registro implica:

- Pérdida de credibilidad ante clientes actuales y prospectos
- Desventaja en licitaciones públicas y privadas (criterio de evaluación obligatorio)
- Daño reputacional permanente — Google indexa las publicaciones de la APDP
- Posible escalamiento a infracción grave o gravísima en caso de reincidencia, que sí conlleva multas de hasta 20.000 UTM
- Compromiso de la relación con aseguradoras de responsabilidad civil profesional

Para profesiones cuyo activo principal es la confianza, la amonestación pública puede tener un impacto económico superior al de una multa privada.

ALCANCE Y LIMITACIONES

Análisis realizado exclusivamente mediante técnicas OSINT y reconocimiento pasivo de superficie, sin acceso a sistemas internos, bases de datos ni código fuente. Los hallazgos reflejan el estado de la infraestructura pública en la fecha de análisis.

S.I.N.S.

La seguridad no es un estado. Es un proceso.

Este informe es el primer paso. S.I.N.S. ofrece acompañamiento continuo para implementar las recomendaciones y preparar a su organización para cumplir con la Ley 21.719 de Protección de Datos Personales, vigente desde el 1 de diciembre de 2026.

PRÓXIMOS PASOS

Revisión de hallazgos críticos
Plan de remediación priorizado
Monitoreo continuo de superficie

CONTACTO

sins.cl
contacto@sins.cl
Santiago, Chile